

Security+ 5.2 · Risk Management

Mestre CyberSec — PDF baseado na aula do Professor Messer · 5.2 — Risk Management (3:30) · [vídeo original ↗](#) · [YouTube ↗](#)

Risk = AMEAÇA × VULNERABILIDADE × IMPACTO no ativo. Assessment (quantitativo em \$ ou qualitativo alto/médio/baixo); ad-hoc (sob demanda); recurring (periódico com register atualizado).

Highlights que a prova cobra

- Risk = ameaça × vulnerabilidade × impacto no ativo
- Risk register: o inventário vivo de risco com owner e plano

Dicas de prova

- 'likelihood x impact' = risk

Cenário clássico: 'probabilidade de ataque + dano financeiro se ocorrer' = risk quantificado.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. RTO (Recovery Time Objective) mede:
- A)** Quanto DADO você aceita perder
 - B)** Quanto TEMPO o serviço pode ficar fora
 - C)** O custo do incidente
 - D)** O número de usuários afetados

2. Cenário corporativo (Risk Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'Risk = ameaça × vulnerabilidade × impacto no ativo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Risk = ameaça × vulnerabilidade × impacto no ativo...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

3. Cenário corporativo (Risk Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'Risk register: o inventário vivo de risco com owner e plano'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Risk register: o inventário vivo de risco com owner e plano...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Risk Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'likelihood x impact' = risk'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'likelihood x impact' = risk...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Risk Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'probabilidade de ataque + dano financeiro se ocorrer' = risk quantificado.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'probabilidade de ataque + dano financeiro se ocorrer' = risk quantificado....

6. Cenário corporativo (Risk Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'Risk = ameaça × vulnerabilidade × impacto no ativo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Risk = ameaça × vulnerabilidade × impacto no ativo...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Risk Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'Risk register: o inventário vivo de risco com owner e plano'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Risk register: o inventário vivo de risco com owner e plano...

8. Cenário corporativo (Risk Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'likelihood x impact' = risk'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'likelihood x impact' = risk...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Risk Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'probabilidade de ataque + dano financeiro se ocorrer' = risk quantificado.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'probabilidade de ataque + dano financeiro se ocorrer' = risk quantificado....

10. Cenário corporativo (Risk Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'Risk = ameaça × vulnerabilidade × impacto no ativo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Risk = ameaça × vulnerabilidade × impacto no ativo...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

- 1) B — Quanto TEMPO o serviço pode ficar fora.** RTO = tempo máximo aceitável de indisponibilidade (quão rápido tem que voltar). Não confundir com RPO (quanto dado pode perder).
- 2) C — Implementar a solução correspondente: Risk = ameaça × vulnerabilidade × impacto .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Management): Risk = ameaça × vulnerabilidade × impacto no ativo. As demais alternativas configuram violações graves de conformidade
- 3) C — Implementar a solução correspondente: Risk register: o inventário vivo de risco .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Management): Risk register: o inventário vivo de risco com owner e plano. As demais alternativas configuram violações graves de co
- 4) B — Implementar a solução correspondente: 'likelihood x impact'=risk....** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Management): 'likelihood x impact'=risk. As demais alternativas configuram violações graves de conformidade ou falhas de controle.
- 5) D — Implementar a solução correspondente: 'probabilidade de ataque + dano financeiro.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Management): 'probabilidade de ataque + dano financeiro se ocorrer'=risk quantificado.. As demais alternativas configuram violação
- 6) C — Implementar a solução correspondente: Risk = ameaça × vulnerabilidade × impacto .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Management): Risk = ameaça × vulnerabilidade × impacto no ativo. As demais alternativas configuram violações graves de conformidade
- 7) D — Implementar a solução correspondente: Risk register: o inventário vivo de risco .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Management): Risk register: o inventário vivo de risco com owner e plano. As demais alternativas configuram violações graves de co
- 8) B — Implementar a solução correspondente: 'likelihood x impact'=risk....** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Management): 'likelihood x impact'=risk. As demais alternativas configuram violações graves de conformidade ou falhas de controle.
- 9) D — Implementar a solução correspondente: 'probabilidade de ataque + dano financeiro.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Management): 'probabilidade de ataque + dano financeiro se ocorrer'=risk quantificado.. As demais alternativas configuram violação
- 10) B — Implementar a solução correspondente: Risk = ameaça × vulnerabilidade × impacto .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Management): Risk = ameaça × vulnerabilidade × impacto no ativo. As demais alternativas configuram violações graves de conformidade

